

2022 年无线通信安全随堂作业

问答题（共七道题目）：

1. 由于使用了无线通信技术使得移动通信系统面临多种安全威胁，请举例说明其中的三种主要威胁。（10 分）

答：（1）**对传递信息的威胁**：这类威胁直接针对在系统中传输的个人消息，例如系统中两个用户之间、网络运行商之间、用户和服务提供商之间的消息等。这类威胁包括：①窃听，即非授权方获悉传输或存储在移动通信系统中的信息；②篡改，即非授权方更改系统中的各种信息，主要是指信息的非法修改和重放，其中信息非法修改包括简单更改（例如，数据位的颠倒）、删除或插入部分消息或文件、删除整个消息或文件、插入新数据或语音信号、调整信息顺序；③抵赖，即参与通信的一方否认或部分否认他的行为，包括接收抵赖和源发抵赖。

（2）**对用户的威胁**：这类威胁直接针对系统中用户的一般行为，例如试图找出用户在什么时间、什么地点在做什么等。包括：①欺诈，即模仿或克隆客户身份从而试图获得对网络和业务的访问；②流量分析，即分析网络中的通信流量，包括信息速率、消息长度、接收者和发送者的标识等；③监视，即监视一个特殊用户的行为。

（3）**对通信系统的威胁**：这类威胁直接破坏整个系统的完整或为得到系统的访问权而破坏局部系统或损坏系统的功能等。包括：①干扰，有拒绝服务，即指系统内部或外部的非法攻击者故意削弱系统的服务能力，或使系统无法提供服务，还有客户态干扰、基站干扰。②资源的非授权访问，即资源的非授权访问是指使用禁用资源或越权使用无线信道、设备、服务或系统数据库等系统资源。禁用资源：指用户根本不允许使用的资源。越权使用资源：指该用户允许使用一些资源，但是该用户所访问的资源超过了其权限范围。

2. 什么是安全域，GSM 标准中给出的匿名、机密性保护和 PIN 码安全机制分别属于哪个安全域？（10 分）

安全域是由一组具有相同安全保护需求并互相信任的系统组成的逻辑区域，分为网络接入域、网络域和用户域的安全，定义分别如下：

网络接入域安全：网络接入域安全主要提供安全接入服务，包括用户身份机密性、用户认证、在网络接入信道和设备间传输数据的机密性和完整性、移动设备的鉴定。

网络域安全：主要提供网络实体间(如交换机和基站之间，交换机和交换机之间)的认证、数据传输机密性和完整性、攻击信息的监视等安全机制。

用户域安全：主要提供终端安全服务模块(可能是终端内的模块或智能卡)与用户间的认证以及终端安全服务模块与移动终端间的认证。

GSM 标准：

匿名机制：通过匿名的方式保护用户身份的机密性，属于网络接如域安全。

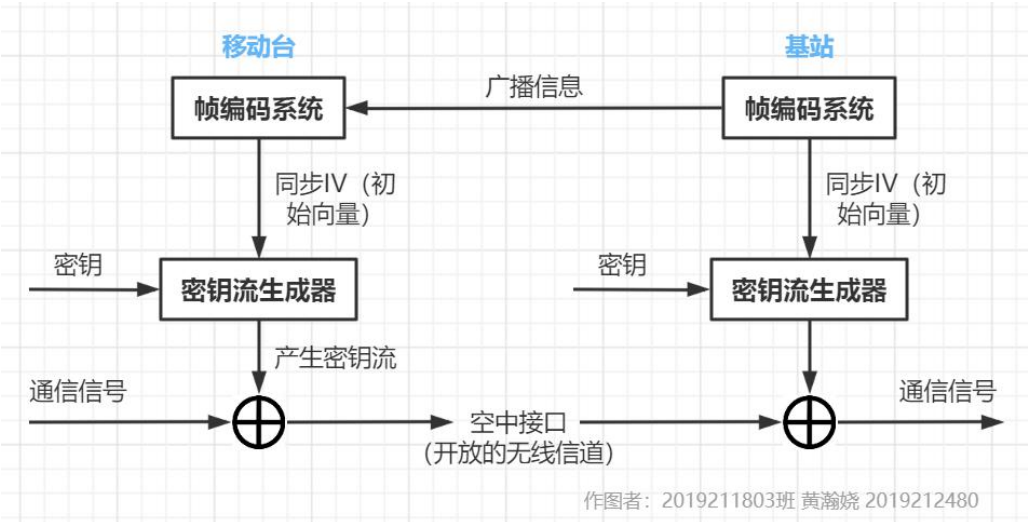
机密性保护机制：GSM 通过空中接口加密来保护数据的机密性传输，属于网络域安全。

PIN 码安全机制：GMS 使用 PIN 码实现用户鉴权，属于用户域安全。

3. 请说明 TETRA 系统空口加密和端到端加密的过程中如何进行密钥流同步的？（10 分）

TETRA 系统空口加密使用过程公网对空口进行加密的过程是一样的，和在 2G 系统中使用的是同样的思路，不同点是 2G 系统的帧号使用的是 Fn。

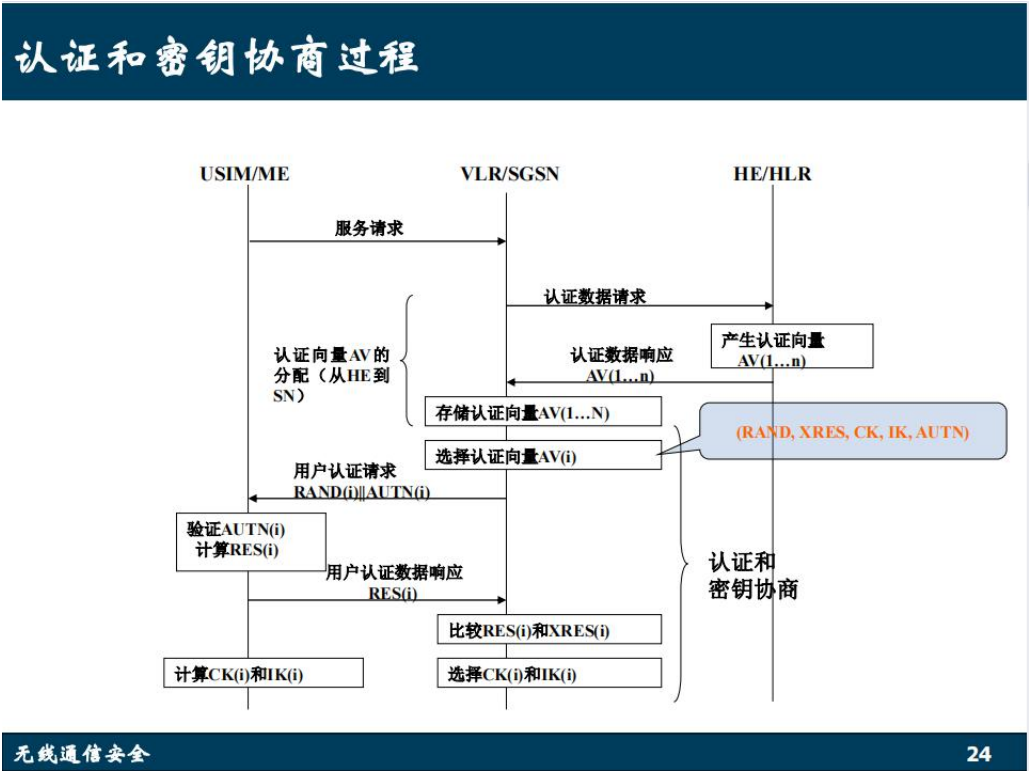
在 TETRA 系统中，空中用留密码加解密的过程如下图所示，其中由 SwMI 维护并通过同步控制(SYNC)和系统消息(SYSINFO) PDU 进行广播来产生用于同步的初始向量 IV。移动台和基站分别通过帧编码系统生成用于空中接口流密码算法的同步 IV，同步 IV 在相同的加密密钥的作用下通过密钥流生成器在移动台和基站上分别生成相同的密钥流，从而起到同步的作用。TETRA 系统的密钥序列发生器 KSG 有两个参数的函数：加密密钥 K 和初始同步向量 IV，IV 的主要作用是移动台和基站建立同步，与在 DECT 和 GSM 系统一样，TETRA 系统也采用帧编号作为 IV 进行发送方和接收方之间的密钥流的同步。使用帧号广播机制：使得基站不停地和移动台广播它所用到的帧号，因此二者有相同的帧号，当作同步向量来完成密钥流的同步。



端到端加密：使用了 E1 和 E3 两个加密算法，采用传输密钥 TEK 和初始向量 SV 作为密钥流发生器 E1 的两个输入生成一个连续的密钥流，该密钥流与语音编码器 CODEC 输出的语音数据流异或，得到在空中信道和 TETRA 系统中传输的密文流，密文流通过空中接口和 TETRA 系统到达接收端，接收端在检测到同步帧后，得到同步向量 SV 和相应的密钥 ID。同步帧是密钥流同步的关键，IV 被包含在同步帧中，并以每秒传送 1-4 次的方法传送给接收方，接收端检测到同步帧，取出同步帧中的同步向量，将该向量传给本地的密钥流产生器，从而完成与发送端的同步。

4. 请说明 WCDMA 系统的 AKA 协议是如何利用认证令牌来认证网络的。
(15 分)

AKA 使用挑战-应答机制，完成用户和网络间的双向身份认证，同时基于身份认证对通信加密密钥进行协商。通过认证和加密手段更好的预防攻击行为，保护移动通信网络资源的安全。
其认证和密钥协商过程如下图所示。



AKA 协议提供用户和网络之间的双向认证，当需要认证时，VLR/SGSN

向 HE/AuC 发送认证数据请求，之后 HE/AuC 向 VLR/SGSN 发送一组含有 n 个认证向量的数据，认证令牌 AUTN 被包含在认证向量里面。当 VLR/SGSN 启动认证和密钥协商时，它从这个序列中选择下一个认证向量，把参数 RAND 和 AUTN 发送给用户，用户端 USIM 检查这个 AUTN 是否可以接受，如果可以，则产生一个相应 RES 回送给 VLR/SGSN，并计算 CK 和 IK。VLR/SGSN 比较 XRES 和来自 MS 和 RES。如果它们匹配，VLR/SGSN 就认为成功地进行认证和密钥交换。过该过程中利用认证令牌来认证网络的方式为：首先，USIM 根据 K 和收到的 RAND 计算出 SQN，然后计算出 XMAC 与 AUTN 中得到的 MAC 相比较，若不同，则向 VLR/SGSN 返回用户鉴权失败信息，并给出失败的原因，同时 VLR/SGSN 也向 HLR 发送认证失败报告，由 VLR/SGSN 决定再启动一个新的鉴权过程；若 MAC 等于 XMAC，则检查 SQN 是否在正确的值域之内，如果不是，则发送同步失败的消息给 VLR/SGSN，同时，放弃这一鉴权过程；如果是，则认为这个参数 AUTN 是可接受的。

5. 在 LTE 安全机制中所定义的密钥派生策略包括了横向衍生方式和纵向衍生方式，请问该方式是否有效保证了切换过程具有前向安全性和后向安全性？请说明原因。（15 分）

LTE 中**横向派生**表示 K_{eNB} *从当前的 K_{eNB} 导出，**纵向派生**表示 K_{eNB} *从 NH 导出;前向安全表示源 eNBbu'nerl

切换安全原则：

后向安全（backward security）：

- (1) 目标 eNB 不能破解源 eNB 与 UE 之前的信息
- (2) 目标 eNB 不能获得源 eNB 使用的密钥

前向安全（forward security）：

- (1) 源 eNB 不能破解目标 eNB 与 UE 之后的信息
- (2) 源 eNB 不能获得目标 eNB 使用的密钥

假设有以下场景：敌手拥有获取空口信号的能力，并控制了源 Enb。

此种情况下，敌手可以获得的密钥参数有：目标 PCI、EARFCN-DL、NCC，以及目标 eNB 选定的接入层保护算法标识。由于敌手又控制了源

eNB, 还可以获得 NH 和 KeNB*, 进而计算出本轮切换产生的新密钥 $KeNB^* = KDF(NH, \text{目标 PCI}, EARFCN-DL)$, 并进一步得到 RRC 和 UP 层的密钥。可见, 完全控制源 eNB 的敌手可以得到本轮切换后新密钥。因此, 上述方案**不具备前向安全性, 但保证了后向安全性**。

6. 请画出无线局域网 802.11i 标准中的 WRAP 协议**最后一个分组的加密和解密**过程, 并简要说明其**加密和解密**的原理。(20 分)

WRAP 是基于 128 位的 AES 在 OCB (offset CodeBook) 模式下使用, OCB 模式通过使用同一个密钥对数据的一次处理, 同时提供了加密和数据完整性检测。

WRAP 的加密原理:

- 构造 OCB 模式 Nonce, 同时 Replay Counter 增加 2 来防止在同一密钥下的 Nonce 重用, 从 AP 到 STA 的包使用奇 Replay Counter, STA 到 AP 则使用偶 Replay Counter。

- 使用 AES 密钥和 Nonce, 进行 OCB 模式加密数据, 将 OCB 模式的 MIC 截为 64 位, 如下:

$OCB-ciphertext || OCB-tag \leftarrow OCB-Encrypt(TK, nonce, data)$

- 把 Replay Counter 插入头部和它的加密数据之间, 如下:

$data \leftarrow \text{Replay Counter} || OCB-ciphertext || OCB-tag$

WRAP 的解密原理:

- 根据发送、接收的 MAC 地址和 Key ID 选择 Key。

- 数据长度至少为 15 字节, 包括 3 字节的 LLC 头和 12 字节的 AES 头。

否则, 丢弃该数据单元。

- 计算该数据单元加密的总块数。

$m = \lceil \text{data}(\text{长度}-12) / \text{AES_Block_size} \rceil$

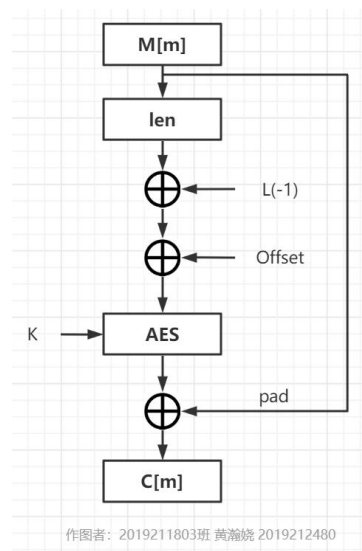
- 如果数据分组的个数 m 与已经接收了的数据分组的个数之和大于 2^{48} , 则密钥 K 支持的加密保护已经耗尽, 接收者丢弃该数据单元, 请求重新生成密钥。

- 从接收包中提取 Replay Counter, 判断序号是否是重复的, 如果是则丢弃。

- 构造 Nonce, 用 AES 密钥 OCB 模式解密数据单元, 然后 OCB-tag

校验正确得到明文，否则包被篡改，丢弃。

加密的最后一步如左图所示：



7. 分析下面的两个无线通信设备之间的保密通信方案存在的缺陷，并给出修改建议和理由。（20 分）

方案说明：为了抵御无线信道中的窃听攻击，实现两个无线通信设备之间的机密性通信，某安全团队设计了如图 1 所示的加解密方案。

加密流程简单描述为：1) 假设无线通信设备已经通过安全信道预先获得了通信密钥 K_s ；2) 由发送端产生随机数作为初始向量 IV；3) 通过 AES 算法的 CBC 模式对任意长度的明文 M 进行加密，生成密文 C ；4) 密文 C 与 IV 进行级联，生成 $IV\parallel C$ 并通过无线信道进行传输。

由于解密流程与加密流程类似，这里省略了解密流程的描述。

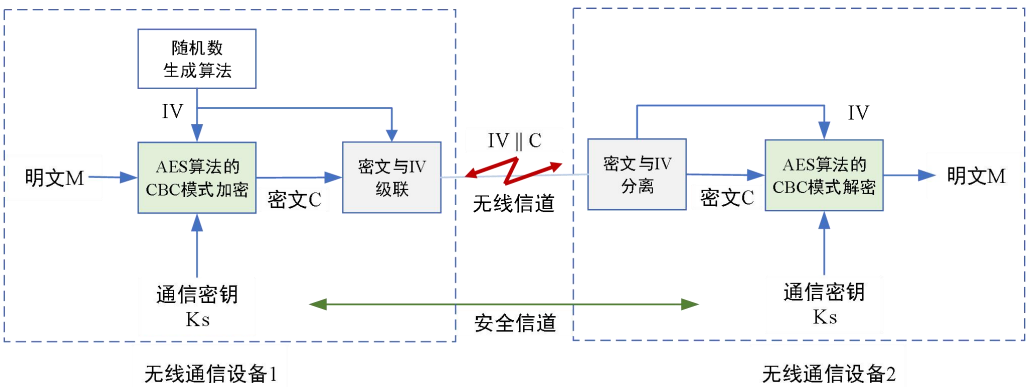


图 1 无线通信设备加解密方案示意图

- 1.该系统使用 AES 的 CBC 模式加密明文，加密的时候，1 比特的明文错误会使得这一个块及之后的块的加密结果都发生错误，因为每一个分组要先和前一个分组加密后的数据进行了亦或运算再进行加密，影响是环环相扣的。解密的时候，1 比特的密文错误只会使得该密文所对应的块和下一个密文块的解密出错，因为解密是密文块解密后在和前一个解密前的密文块异或运算得到结果。且该加密模式不支持并行计算，效率较低。AES 安全性较低，建议使用安全性高的加密算法与加密模式。
- 2.缺少对消息的完整性检验和实体间的双向认证，建议使用 MAC、签名算法以及其他更安全的方式进行完整性检验和身份认证。
- 3.初始向量 IV 与密文一起传输，这会使得 IV 容易遭到攻击，如窃取、篡改等，建议 IV 加密后再进行传输或通过安全信道传输。
- 4.这个过程中缺少了不可否认服务，因此建议使用合法的监听机制来防止通信双方否认自己的通话。

结束
